

##CRISCd - Information Technology and Security Principles

###Objectives:

At the end of this episode, I will be able to understand:

1. Practitioners need to understand the CIA triad as all security risk derives from these three principles
2. Sometimes called the Iron Triangle
3. There is a fourth principle in addition to confidentiality, integrity and availability: Nonrepudiation
4. All are needed to perform successful risk management
5. Confidentiality is all about the secrecy and privacy of data
6. Risk practitioners should be on the lookout for policies or actions that violate: Need to know and Least privilege
7. Integrity is All about protecting data from improper modification, exclusion or destruction
8. Relies upon levels of error checking and verification
9. Principle of least privilege is critical when identifying risk
10. Availability is All about providing timely and reliable access to information
11. Systems and data need to be highly available (HA)
12. High availability can be expensive and needs to be assessed with CBA
13. To identify potential risk, compare current levels of availability to desired levels (gaps=risk)
14. Other aspects of the CIA triad to consider:
 - System Authorization
 - Segregation of Duties (SoD)
 - Cross-training and Job Rotation

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>